$ ./init.sh

Phishing Expedition

Tales from When You Take the Bait



João Pedro Dias (@jpdias)

[0x2D6C203133337] - The Meet // ØxOPOSÆC

04/11/2026

$ whoami

João Pedro Dias

Solutions Architect @ Yonderland

jpdias[@]outlook.com
jpdias[@]pm.me

jpdias.me || linkedin.com/in/joaopdias

$ cat expedition.log

The expedition

1. Context and Inboxes
2. Bulk analysis and categorization
3. The deep dive
4. Easy is the way
5. Takeaways

$ cat expedition.log

The expedition

1. Context and Inboxes
2. Bulk analysis and categorization
3. The deep dive
4. Easy is the way
5. Takeaways

$ echo “hello world” | cowsay

“Every day, roughly 3.4 thousand million phishing emails reach inboxes worldwide.”

UN Office on Drugs & Crime, Jan. 2026

$ wc -l corpus/*.eml

Context

5 inboxes + 2 aliases

raw .eml files

8 months

March to October 2026

183 emails

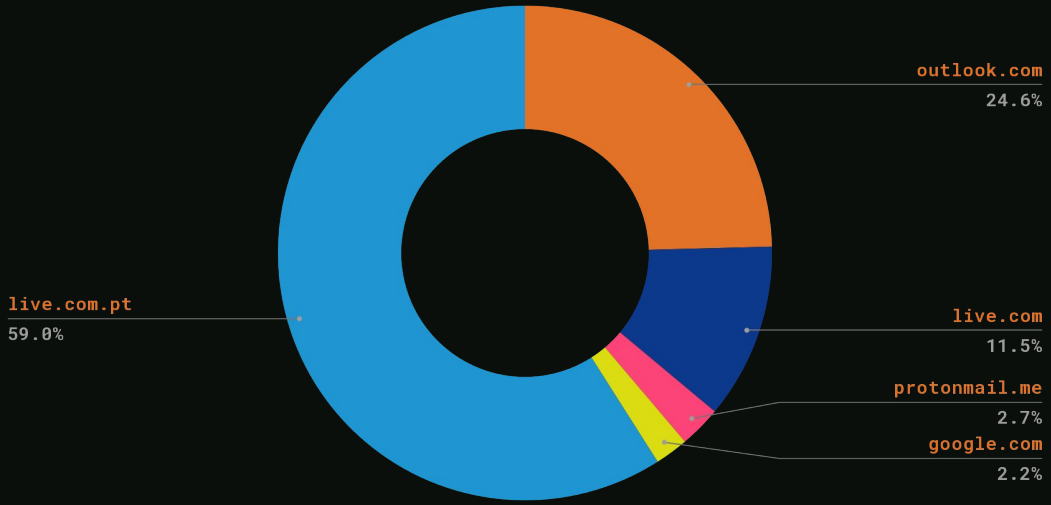
131 unique domains

15 brands

targeted across inboxes

$ wc -l corpus/*.eml

Inboxes



The oldest email (with alias) gets the most spam, no surprises there.

$ cat expedition.log

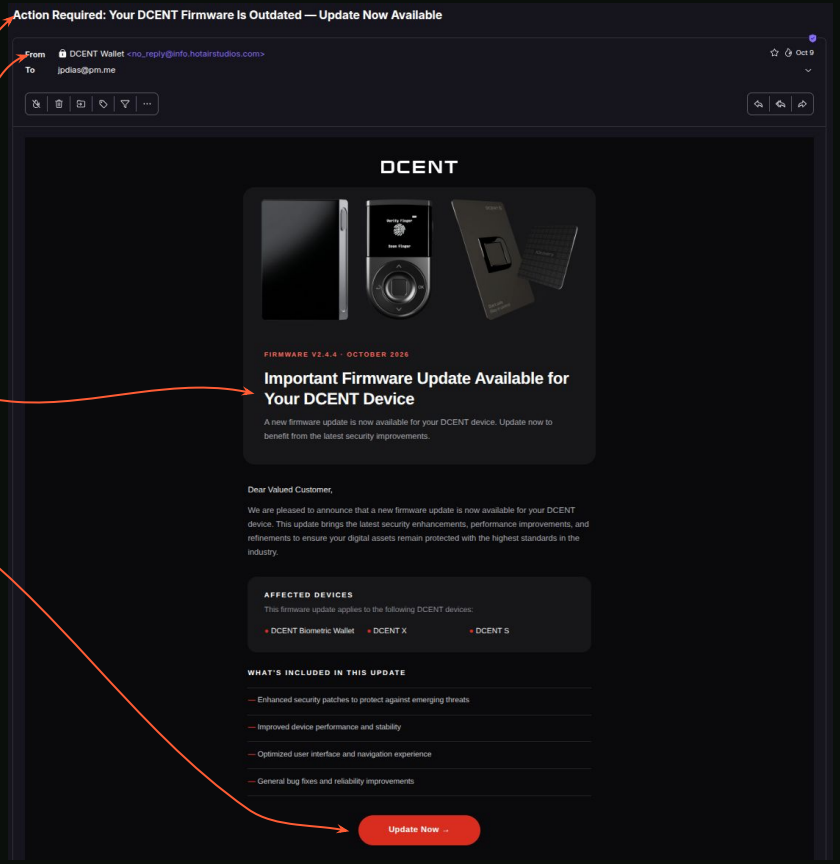
The expedition

1. Context and Inboxes
2. Bulk analysis and categorization
3. The deep dive
4. Easy is the way
5. Takeaways

$ less 01-the-bait.eml

Anatomy of a lure

- Subject and urgency
- Sender and display name
- Tone and language
- The call to action



$ make analysis

From .eml to metrics

1. Ingest

auth, links, file hashes

>

2. Classify

17 clusters (target & business domain & style)

>

3. Enrich

DNS, WHOIS (RDAP), Certificate Transparency, urlscan, VirusTotal

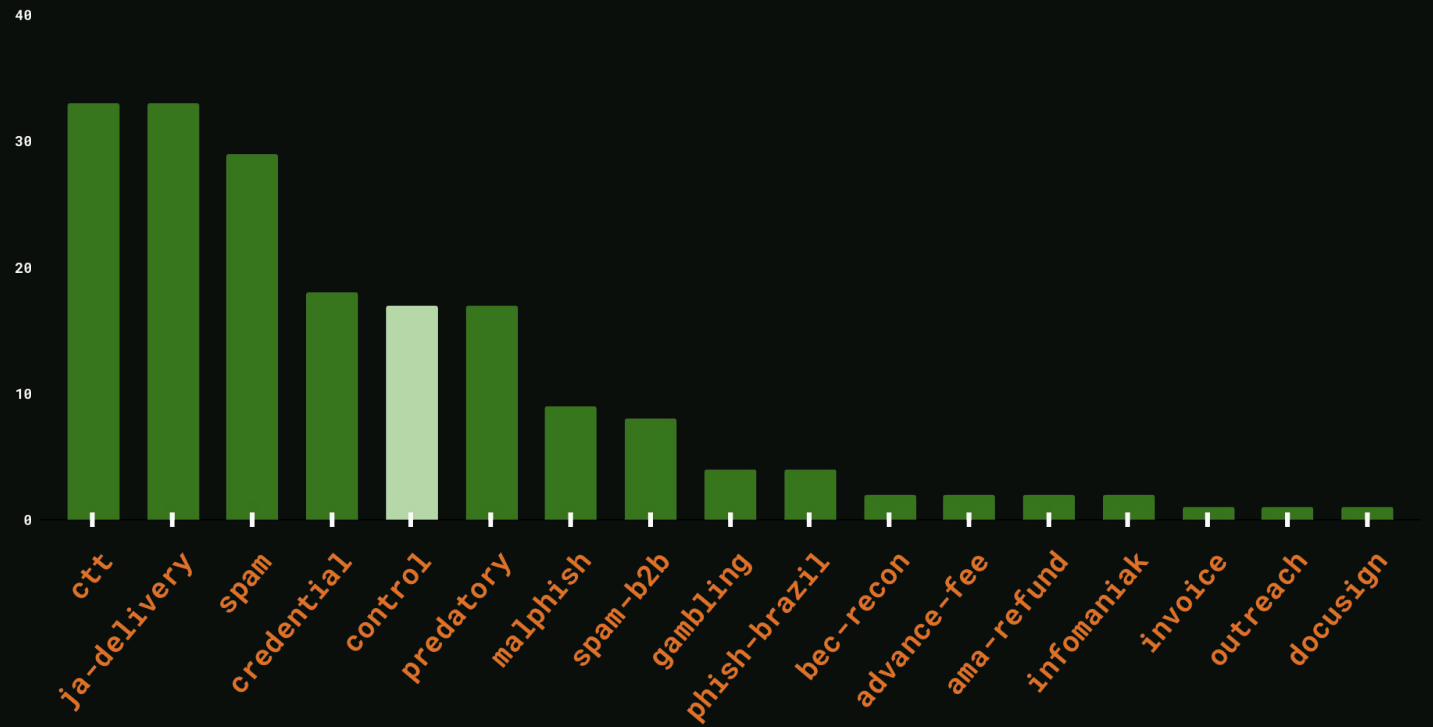
>

4. Report

catalog.csv, ~45 variables

$ make analysis

Mail cluster distribution



$ ./enrich --domains

Gathering information

Dig + dnspython	Checks sender domain records including MX / TXT / NS / A per domain (who is allowed to mail, who handles mail).
ListSignal	Shows when a domain was first seen, who hosts it, and who provides its mail.
urlscan.io	Looks up past scans of web links and runs private scans of suspicious pages.
Certificate Transparency logs	Finds when a domain first got a security certificate and what subdomains exist.
Spamhaus blocklist	Checks if a domain appears on known spam, phishing, or malware lists.
VirusTotal	Scans files and domains against many security engines at once.
dnstwist	Generates lookalike domain names to see if attackers registered similar ones.

$ make analysis

Authentication shenanigans

What Outlook reported

- 149 / 183 emails passed SPF.
- But SPF checks the envelope sender (Return-Path), not necessarily the visible From: address.

What the analysis tells

- 146 / 149 SPF-passing emails had an authenticated domain different from the visible From: domain.
- 3 / 149 Had an exact domain match.

What those domains published (131 unique domains):

- 67 had no SPF record
- 39 used SPF softfail (~all)
- 105 had DMARC policy p=none
- 34 had DKIM keys found

Auth pass != sender identity verified != legitimate email

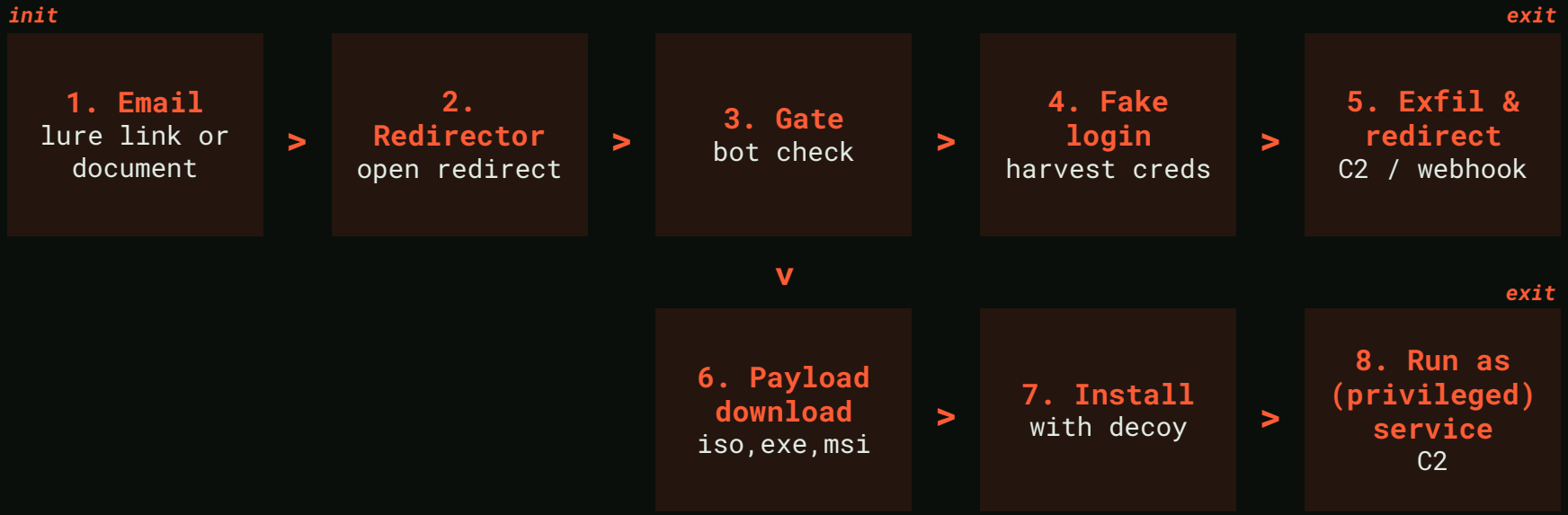
$ cat expedition.log

The expedition

1. Context and Inboxes
2. Bulk analysis and categorization
3. The deep dive
4. Easy is the way
5. Takeaways

$ curl -L --max-redirs 10

Anatomy of a multi-hop chain

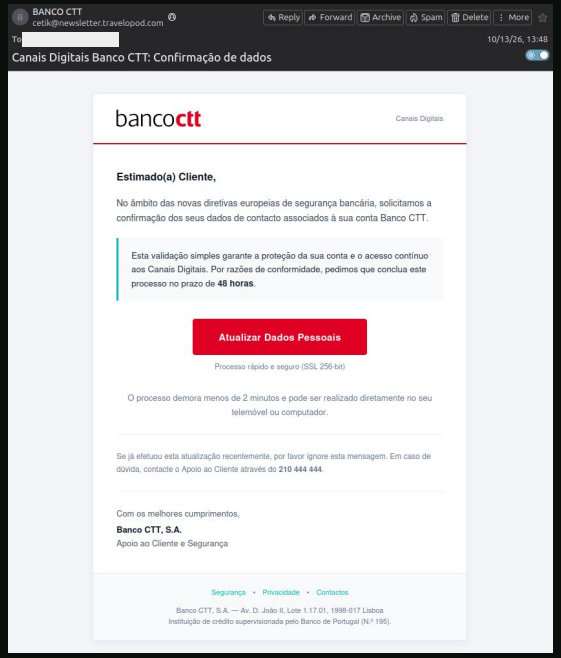


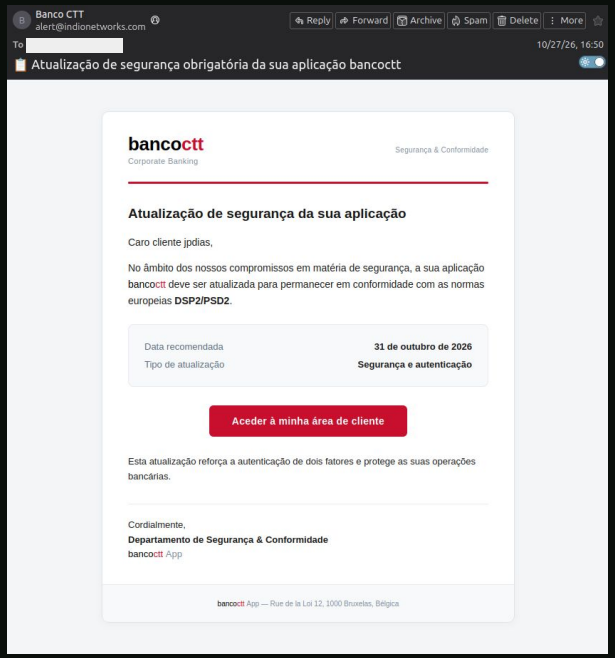
$ top ctt.log

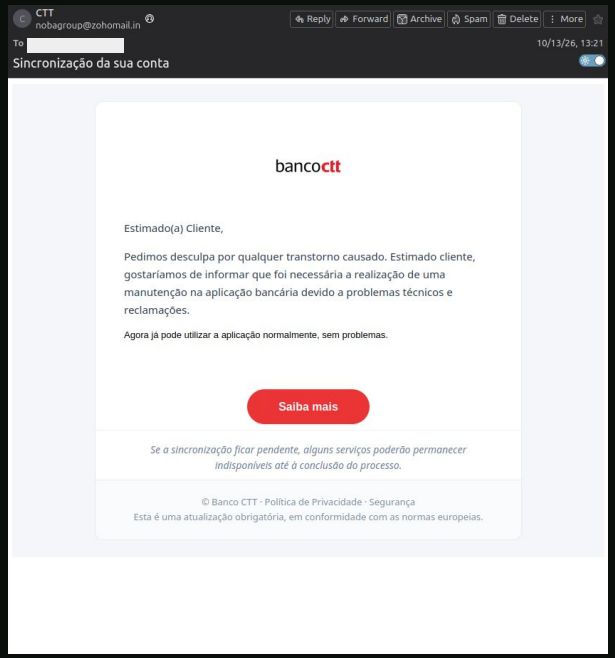


$ claude “make me a sandwich”

The CTT credential-phish cluster (33 emails)







$ cat case-file-00.md

CTT playbook

1. Email

trusted ESP relay commerce7

>

2. Redirector

Bing ck/a (200 JS forward)

>

3. Redirector

Google DoubleClick (302)

>

4. Landing

cloudflare-fronted portal (pt.banco-ctt-2026.com proxy)

>

5. Credential harvest form (exfil)

Redirect to legitimate page

$ tail case-file-00.md

The CTT credential-phish cluster (33 emails)

Same CTT bank phish ("*Atualização de dados*", "*Restrição de Acesso por Segurança*") sent from:

- Trusted ESPs (13): commerce7.com/shopify (5), zohomail.in (2), operto.com (2), planhero.com (1), brivity.com (1), instabook.io (1), zohomail.eu (1)
- Random compromised domains or single-use domains (20): casinos.gub.uy (Uruguay gov), icmai.in (Indian institute), cnb.avocat.fr (French lawyer), grandislandvineyards.com (vineyard), 63edu.ru (Russian edu), vh19347.vh.net.pl / vh19588.vh.net.pl (Polish hosting), localhost.co.uk, vagary.net, etc.

Zero came from bancoctt.pt or compromised CTT mailboxes.

```
$ cloudflared access tcp --hostname ://example.com --url localhost:8080
```

Cloudflare as the new perimeter

Origin shielding

The public-facing address points to Cloudflare, obscuring the server and complicating direct attribution or takedown.

Traffic gatekeeping

A front page or challenge may filter visitors before redirecting selected traffic to a phishing page or malware payload.

Fast infrastructure changes

Operators can change backend hosting while keeping the front door stable, making IP-only blocking less durable.

Reputation & TLS

Valid edge TLS and a familiar intermediary can make a malicious destination appear less suspicious at first glance.

Low barrier to entry

Free DNS, TLS and basic protection lower setup costs for short-lived domains; legitimate use of the same services is common.

Shared infrastructure

Shared anycast IPs mean blanket IP blocks can affect unrelated sites. Focus on domain, URL, behavior and account-level signals.

```
$ node -e "require('child_process').execSync('bash', {stdio: 'inherit'})"
```

JavaScript holds the door

JS-level check	How it works	Blocks / limitations
User-Agent switch	Checks browser and OS identifiers.	Basic sandbox filters.
reCAPTCHA gate	Requires a verified CAPTCHA token.	Impedes automated scanners.
IP geolocation	Checks visitor country via IP lookup.	Filters non-target regions.
Headless detection	Checks webdriver, plugins, and lang.	Detects some automated browsers.
Mouse / interaction	Requires mouse movement or clicks.	Filters non-interactive scanners.
Debugger detection	Uses debugger and timing checks.	May disrupt debugging; unreliable.
Timing / environment	Checks execution timing and device signals.	Flags unusual environments.

$ top otp.log



$ cat case-file-01.md

On the hook of a phisher: the flow

1. Email
invoice lure from a gmx.net account

>

2. HTM attachment
document.write(unescape(...))

>

3. Fake login
Microsoft clone, email pre-filled

4. Obfuscated JS
fake error, 2 tries, then redirect

>

5. def.php
POST of ai and pr on a hacked store

>

6. PHPMailer
creds and IP mailed to the attacker

$ tail case-file-01.md

On the hook of a phisher: takeaways

- The HTML attachment unescapes itself: a cheap filter bypass
- Deobfuscated with JSNice and synchrony, then by hand
- An exposed dwsync.xml (Dreamweaver) leaked the hacked host's files
- The same PHP kit sits on GitHub: attackers adopt open source
- def.php returned 404 when checked

Tools used

JSNice
synchrony
GitHub code search
gist

Source: jpdias.me/infosec/2022/07/30/phishing-story

$ top uphold.log



$ cat case-file-02.md

Plywood Trojan: the flow

1. Email fake Uphold desktop app

>

2. Vercel site fresh domain, bulk registrar (via ngrok)

>

3. Gofile Uphold-installer.exe

>

4. Signed installer bundled Syncro RMM

>

5. Trial tenant attacker's own RMM account (C2)

$ tail case-file-02.md

Plywood Trojan: takeaways

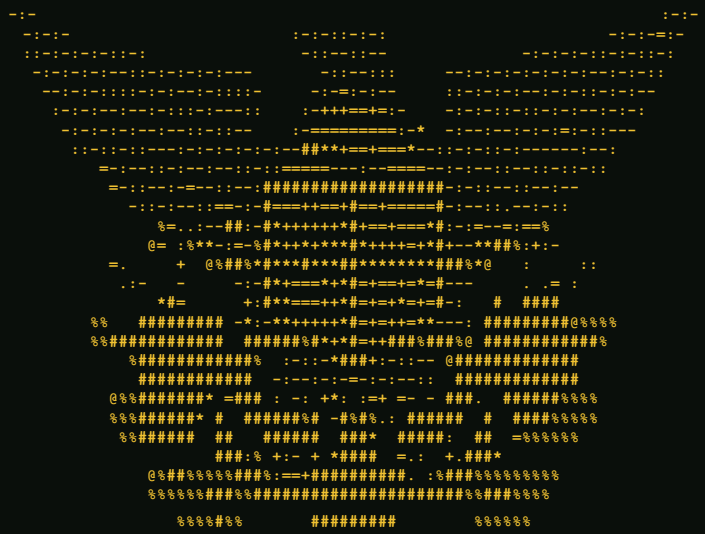
- Not malware: a vendor-signed RMM installer
- Only 8 of 72 AV engines flag it
- The registrar sells domains in bulk with a free reseller API
- Reported on the 16th, domain down on the 17th

Tools used

urlscan.io
VirusTotal
ANY.RUN
WHOIS
abuse.ch Bazaar
jwt.io

Source: jpdias.me/infosec/2025/11/17/trojans-made-easy

$ top fire-department.log



$ cat case-file-03.md

VoicePress5: the flow

1. Email
invoice PDF via a trusted ESP

>

2. PDF
OneDrive link, button hides t.co

>

3. Free host
Hostinger site, UA + reCAPTCHA

>

4. ngrok page
same UA check, pdf.php

5. VBS
downloader and decoy Drive page

>

6. Gofile ZIP
Java runtime, JAR named .png

>

7. Ratty RAT
obfuscated, config in checksum

>

8. C2
Aruba cloud server, port 7711

$ tail case-file-03.md

VoicePress5: takeaways

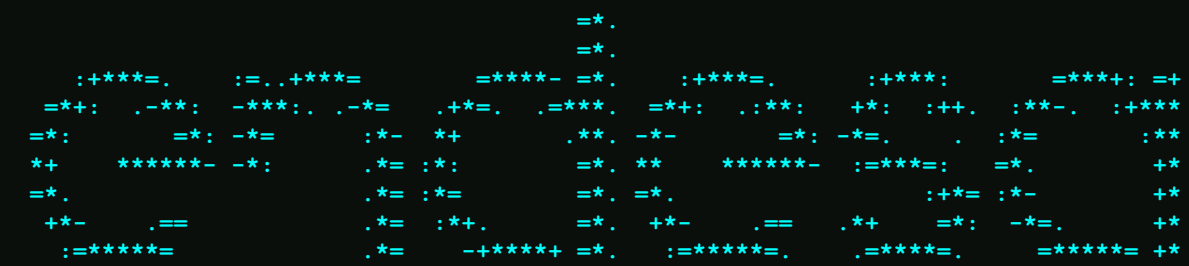
- Extra hops lower the odds of automated follow-up
- Windows Chrome or Edge only; mobile is told to use a desktop
- Config hidden in a file called checksum (AES)
- 23 of 68 engines flag the JAR
- IP and OneDrive file reported, both taken down in days

Tools used

urlscan.io
curl + UA switcher
JD-GUI
VirusTotal
Claude
MXtoolbox

Source: jpdias.me/infosec/2026/03/04/email-to-rat

$ top invoice.log



$ cat case-file-04.md

Beyond Context Windows: the flow

1. Email
Endesa bill, correct Portuguese

>

2. Landing
Bing redirect or Wix page

>

3. ISO
slips past gateway scanners

>

4. VBS
string splits, 7 Base64 vars

5. 3 MB ZIP
inflates to a 116 MB PE

>

6. Grandoreiro
Delphi trojan, sandbox checks

>

7. C2 via DGA
14 domains a day, DoH

$ tail case-file-04.md

Beyond Context Windows: takeaways

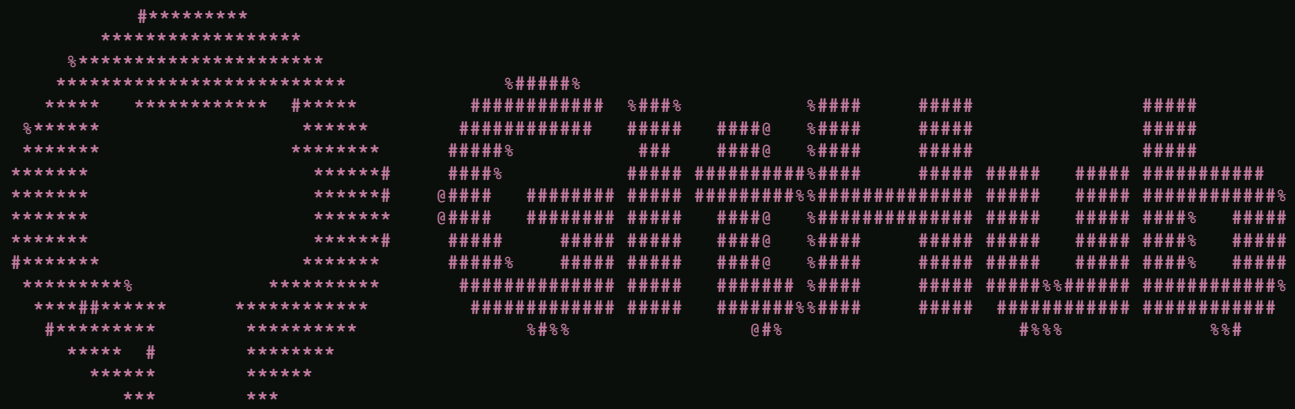
- 94% of the PE is a white bitmap (0xFF): an unpacking/compression bomb
- Too big for sandboxes and for LLM context windows
- AI wrote the tools: a deobfuscator and a PE resource shrinker
- Checks: ip-api geofence, printer, debugger, RAM
- Tor and VPN egress satisfied the geofence

Tools used

OpenCode
any.run
Custom AI scripts
objdump
VirusTotal

Source: jpdias.me/infosec/2026/06/13/old-tricks-fighting-ai-analyst

$ cat .git/HEAD



$ cat case-file-05.md

Malware in the Shell: the flow

1. Email
DCENT firmware or tax lure

>

2. Cloudflare
bot check (Uphold wave)

>

3. GitHub release
shell account, one asset

>

4. Wrapper
bat or zip, 3 packing styles

5. DocuSign
legit installer as a decoy

>

6. ScreenConnect
MSI, silent, as SYSTEM

>

7. C2
6 domains, port 8041

$ tail case-file-05.md

Malware in the Shell: takeaways

- Two-week-old shell accounts: default avatar, one README, one release
- Same file under many brand names: 151 files, 43 unique
- A real DocuSign installer is the decoy while ScreenConnect installs
- 7 MSI builds, 6 C2 domains, all on port 8041
- 8 accounts found, reported, down in about 48h

Tools used

GitHub API + own hunting script
OpenCode: unpackers
7z + pefile
ANY.RUN

Source: jpdias.me/security/2026/10/11/github-hosted-malware

$ upx --best trojan.exe

Old tricks, lots of layers

Trick category	What it does	Example
Size bombs	Exceeds automated scanning size limits and uses lots of AI credits.	0xFF bitmap that unpacks to big files (~100mb)
Dead / obscure languages	Increases reverse-engineering effort and limits automated tooling.	Delphi
Obfuscation layers	Defeats static signatures and increases deobfuscation costs.	Packers, Obfuscators
Domain churn	Forces continuous updates to reputation databases and blocklists.	Free (sub)domains (e.g. Vercel, ngrok)
Encrypted C2 resolution	Reduces visibility for DNS-based monitoring and analysis.	Google DoH usage
Resource bloat	Increases sandbox execution time and resource consumption.	Adding useless files (e.g. PDFs, images) to the payload.

$ cat expedition.log

The expedition

1. Context and Inboxes
2. Bulk analysis and categorization
3. The deep dive
4. Easy is the way
5. Takeaways

$ ./attacker --budget 0

Low-key attacker, at scale

1. Free tiers of email campaign providers
2. AI-written emails: right brand, location and language
3. Free web storage: old shared hosting or new ones like Vercel
4. Cloudflare and/or Ngrok free tier as the mask
5. Official open redirects (Google, Bing) to borrow reputation

Free tiers all the way down.

$ ./attacker --goal data

For data theft, this is enough

Goal
steal logins and card details

Needs
a form, a mask and a redirect

Example
CTT: 33 emails, 13 legitimate ESPs abused

The campaign stops here: no payload to build.

$ ./attacker --goal rat

Distributing RATs: also free

1. Free RMM thousands, no ID check > **2. Free tier** up to 100 devices > **3. Automate** free, at scale > **4. Brand it** custom executables > **5. Trusted host** GitHub releases and similar

Takedown comes? Keep spamming.

Plywood Trojan: signed Syncro RMM installer, 8 of 72 AV detections.

$ cat expedition.log

The expedition

1. Context and Inboxes
2. Bulk analysis and categorization
3. The deep dive
4. Easy is the way
5. Takeaways

$ echo $?

The same old phish, but now with AI

1. **Trust is borrowed.** Legitimate ESPs, redirectors, hosting providers and signed software become part of the attack chain.
2. **The infrastructure is disposable.** Domains, accounts, hosting and delivery mechanisms can be replaced independently.
3. **Malware isn't always malware.** Sometimes the attacker just needs legitimate software and their own account.
4. **The payload is only part of the problem.** Delivery, gating, geofencing and execution conditions matter just as much.
5. **Analysis has a cost.** Obfuscation, oversized resources, environment checks and infrastructure churn consume investigation time.
6. **Automation changes the economics.** Cheap infrastructure and reusable tooling make campaigns easy to replicate.
7. **Following the chain beats looking at the email.** The interesting evidence is often several hops away.

$ echo “hello world” | cowsay

“Generative AI writes phishing emails now. They're grammatically clean, contextually accurate, and tailored to the specific person receiving them. The *obvious tells that security training decks have relied on for a decade are becoming less reliable by the month*."

Valimail Threat Research Team,
https://www.valimail.com/blog/phishing-email-red-flags/

$ exit 0

Questions?

João Pedro Dias (@jpdias)



jpdias.me || linkedin.com/in/joaopdias